

CookieMonster: Cookie Hijacking

CookieMonster: Cookie Hijacking - Author not stated, fscked.org.

- Published: date not stated
- Original: <<https://fscked.org/projects/cookiemonster>>
- Preserved from: <https://fscked.org/projects/cookiemonster> (live) on 2026-08-08
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

CookieMonster: Cookie Hijacking | fscked.org

Cookiemonster

: 4 12 2024

|
|

CookieMonster: Cookie Hijacking

Submitted by mikeperry on Mon, 08/04/2008 – 04:08

- [CookieMonster](#)
- [DEFCON](#)
- [InsecureCookies](#)
- [Projects](#)
- [Python](#)
- [Security](#)

| |

Cookiemonster is a proof of concept python-based cookie hijacking utility that is able to capture cookies of improperly secured HTTPS sites via the local network. In its [default mode of operation](#), Cookiemonster tracks the HTTPS sites visited by a each local client IP and then automatically injects HTML elements for each HTTPS domain into subsequent regular HTTP requests to a particular client. This causes any insecure HTTPS cookies from the automatically collected target

domains to be transmitted unencrypted for capture by Cookiemonster, which then writes them into Firefox 2.0 or 3.0 compatible cookie files.

Background and Epic Saga

I originally announced the common web vulnerability that Cookiemonster exploits in 2007 on the security mailing list [BugTraq](#), but the issue received little attention. So a year later, I decided to develop Cookiemonster as a proof of concept tool and [presented it](#) at Defcon 16 in Las Vegas. I basically attempted to hold the web hostage under threat of releasing it to attempt to encourage web developers to fix the vulnerabilities. I had two goals: Encourage widespread SSL adoption, and raise awareness that it is often done incorrectly.

For a while and to some extent, it did work: I was able to drum up enough press around the issue that people paid attention, and some sites got fixed. Unfortunately, I was not able to keep the drums beating loud enough or long enough, and many sites are still vulnerable to hijacking even for users who use https (including Gmail, in their default account configuration).

I attempted to get the tool in the hands of as many security researchers, students, and web developers as possible during and after the PR storm. I made a set of scripts to email releases out to people I deemed worthy, but managing that process got to be annoying. It also wasn't [the right way to handle the situation](#), but one I chose mostly in an attempt to maintain leverage and keep dialog open with some of the larger companies I was dealing with, who seemed reluctant to invest in the infrastructure needed for SSL or even a [mixed-mode fix](#), but were willing to at least talk to me while I delayed the tool.

Ultimately, the [status quo basically solidified](#) around October of 2008, and I should have released the tool right then, but I kept promising myself I would clean it up a bit, write some unit tests, and get the relevant patches committed upstream. Ha! Lies! I also needed a break from juggling what were essentially the 3 jobs I was working at the time. So I took some time to decompress, and just focused on [finishing up at my day job](#).

It took me till the holidays of 2008 to finally find some time to [check the project in](#) to Google Code, make it easy to build and patch the libraries it depended on, and write these posts. Hopefully the widespread release of the tool will help to raise awareness a bit more.

Releases and SVN access:

- [Cookiemonster-20080909](#)
- [SVN instructions](#)

More Information:

- [Functional Overview](#)
- [Core Logic Loop](#)
- [Other postings about Insecure Cookies](#)

